□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□ AI □□□□□□□□□□□□□□□□□□□□□□□□□□

□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□ *OWASP* □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□

□□□□□□□□□ 1.0
□□□□□□□□□□□ 12 □□□□□□□ 2026
□□□□□□□□□□□□□□□□□□□□□□□□□□□□□

□□□□□□

- □□□□□ 1: □□□□□□□□□□□□□□□□□□□□

□□□

	Suite, Acunetix	□□□□□□□□□□□□
Dependency Check	Snyk, Dependabot, npm audit	□□□□□□□□□□□□□□□□□□□□

□□□□□ 2: □□□□□□□□□□□□□□□ OWASP Top 10:2025

□□□□□□□□□□□□□□□□□□□

2.2 A02: Security Misconfiguration (□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□)

□□□□□□□□□□□: □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□ □□□□□ □□□□□□□□□□□□□ □□□□□□□□□□□□□□□□□□□□

2.3 A03: Supply Chain Failures (□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□)

□□□□□□□□□□□: □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□ □□□□□□□□□ □□□□□□□□□□□□□□□□□□□□

```
    private final Map<String, CryptoAlgorithm> algorithms = new
HashMap<>();

    public ConfigurableCryptoService() {
        // □□□□□□□□□□□□□□□□□□□□
```

STRIDE Threat Modeling:

Threat	□□□□□□□□□	□□□□□□□□□□□□□□□□□□
Spoofing	□□□□□□□□□□□□□□□	Authentication, MFA, Digital Signatures
Tampering	□□□□□□□□□□□□□□□□□□□□

```
    private final PasswordEncoder passwordEncoder =
        new Argon2PasswordEncoder(16, 32, 1, 15, 2);  // □□□□□□□□□□
OWASP

    public void registerUser(String email, String password) {
        String hashedPassword = passwordEncoder.encode(password);
        userRepository.save(new User(email, hashedPassword));
    }

    public boolean authenticateUser(String email, String rawPassword) {
        User user = userRepository.findByEmail(email);
        if (user == null) {
            return false;  // □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□
        }

        boolean isValid = passwordEncoder.matches(rawPassword,
user.getHashedPassword());

        if (!isValid) {
            recordFailedAttempt(email);  // □□□□□□□□□□□□□□□□□□□□□□□□□
            checkForAccountLockout(email);
        }

        return isValid;
    }
}
```

2.8 A08: Software & Data Integrity Failures (□□□□□□□□□□□□□□□□□□□

Events	attempts, MFA	
Authorization Changes	Role changes, Permission updates	1 □□
Data Access	Read/Write/Delete operations on sensitive data	1 □□
System Changes	Configuration changes, Patch deployment	1 □□
Security Events	WAF blocks, IDS/IPS alerts	30-90 □□□

SIEM/SOAR Integration:

```
# □□□□□□□□□: Structured Logging (JSON format)
{
  "timestamp": "2025-03-12T10:30:45Z",
  "event_type": "authentication_failure",
  "user_id": "user123",
  "ip_address": "203.0.113.45",
  "user_agent": "Mozilla/5.0...",
  "failure_reason": "invalid_password",
  "failed_attempts": 3,
  "account_lockout": false,
  "source": "auth_service",
  "severity": "MEDIUM"
}

# □□□□□□□□□ SIEM □□□□ syslog/HTTP
# □□□□□□□□□□□□ alert □□□□□ failed_attempts > 5
```

2.10 A10: Using Components with Known Vulnerabilities (□□□□□□□ □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□)

□□□□□□□□□□□: □□□ library □□□□ framework □□□□□□□□□□□□□□ CVE

□□□□□□□□:

□□□□□□□	□□□□□□□□□□□	□□□□□□□□□
Dependency Scanning	□□□ Snyk, Dependabot, npm audit	□□□□□□ CVE □□□□□ □□□□□
Automated Updates	Pull requests □□□□□□□□□□□□□□□□□ security patches	□□□□□□□□□□□□□□□□□□ □□□□□□□□
Safe-fail Architecture	□□□□□□□ graceful degradation	□□□□□□□□□□□□□□□□□□□□□□ □□□□□□□□□□□□□
Chaos Testing	□□□□□□□□□□□□□□□□□ failure	□□□□□□□□□□□□□□□□□□□□ □□□□□□□□

2.11 LLM Security & AI Models

□□□□□□□□□□□: □□□□□□□□□□□□□□□□□□□□

Multi-layer Guardrails Framework:

```
# □□□□□□□□□: LLM Security Guardrails
1. Input Validation Layer
   - □□□□□□□□□□□□□□□□□□□□ prompt
   - □□□□□□□□ prompt injection patterns
   - □□□□□□□□□□□ sensitive PII

2. Rate Limiting & Quota
   - □□□□□□□□□□□□□□□□□□□□□□□ user
   - □□□□□□□ token consumption
   - □□□□□□□□□□□□□□□□□□□□□□□□□□

3. Output Filtering
   - □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□ sensitive
   - □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□
   - □□□□□□□□□□□□□□□□□□□□□

4. Model Monitoring
   - □□□□□□□ behavior anomalies
   - □□□□□□□□ gradient/backprop attacks
   - □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□

5. Jailbreak Defense
   - □□□□□□□□□□□□□□□□□□□□ jailbreak
   - □□□□ prompt engineering
   - □□□□□□□□□□□□□□□□
```

□□□□□ 3: □□□□□□□□□□□□□□□□□□□□

Consent	□□□□□□□□□□□□□□□□□□□□

3.5 Open Data Governance for ITA

Publishing government data publicly while maintaining security and privacy

□□□□□□ Data	□□□□□□□□□	Format	Publishing
Non-sensitive	Budget, Statistics, Public events	CSV, JSON, RDF	data.go.th
Anonymized	Aggregated demographics	CSV, JSON	data.go.th
Restricted	Sensitive but approved	API + Auth token	Authorized users only

□□□□□ 4: □□□□□□□□□□□ □□□□□□□□□□ □□□□□□□□□□□□□□□□

□□□□□□□□□□□□□□□□□□□

□□ (Follow-up)	Ongoing	Investigation status, remediation steps
Final Report	30 days	Root cause, lessons learned, improvements

4.4 Incident Response Plan - NIST SP 800-61 Rev.3

Phase	Duration	Actions
Preparation	Continuous	Create IR team, tools, training
Detection & Analysis	1-24 hours	Identify incident, scope, severity
Containment	24-72 hours	Stop spread, isolate systems
Eradication	1-2 weeks	Remove malware, fix vulnerabilities
Recovery	1-4 weeks	Restore systems, validate

4.5 SIEM/XDR/SOAR Integration

Security Information and Event Management (SIEM): □□□□ log collection

Extended Detection and Response (XDR): □□□□□□ endpoint, network, cloud detection

Security Orchestration, Automation and Response (SOAR): □□□□□□□□□□□□□□ □□□□□□□□□□□□□□□□□□

- Log Collection: Fluent Bit, Filebeat, Logstash
- Log Storage: Elasticsearch, Splunk, Graylog
- Alert & Detection: YARA, Sigma rules, Custom detections
- Playbook Automation: Ansible, Python scripts
- Incident Management: JIRA, ServiceNow

4.6 Security KPIs - 7 Core Metrics

KPI	Target	Frequency
Vulnerability Remediation Rate	90% critical in 30 days	Monthly
Mean Time to Detect (MTTD)	< 24 hours	Monthly
Mean Time to Respond (MTTR)	< 4 hours	Monthly
Patch Management Compliance	>= 95% up-to-date	Weekly
Phishing Click Rate	< 3%	Quarterly
Employee Security Training Completion	>= 95%	Quarterly
Incident Response	>= 80%	Semi-annually

Drill Pass Rate		

4.7 Cloud Compliance Audit

- Configuration Review: Security groups, IAM roles, S3 bucket policies
- Encryption Audit: At-rest (KMS, TDE) and in-transit (TLS)
- Logging & Monitoring: CloudTrail, VPC Flow Logs, WAF logs
- Compliance Mapping: AWS CIS Benchmarks, SOC 2, FedRAMP
- Remediation Tracking: High/Medium/Low risk fixes

□□□□□ 5: □□

□□□□□□□□□□□□□□□□□□□

- Phase 3 (2026-2027): Hybrid Mode - Run PQC alongside current crypto
- Phase 4 (2027-2028): Migration - Switch to PQC for all systems
- Phase 5 (2028+): Sunset - Retire legacy crypto

Algorithm	Type	NIST Status
Crystals-Kyber	Key Encapsulation	Standardized (ML-KEM)
Crystals-Dilithium	Signature	Standardized (ML-DSA)
Sphincs+	Signature	Standardized (SLH-DSA)
Falcon	Signature	Candidate

5.4 Zero Trust 2.0 Implementation

Zero Trust: □□□□□□□□□□□□ □□□□□□□□□□□□□ □□□□□□□□□

- Identity Verification: □□□□□□□□□□□□ user □□□□ MFA, device certificate
- Device Security: □□□□□□□□□□□ device □□ patch, antimalware, encryption
- Microsegmentation: □□□□ network □□□□□□□□□□□□□ □ □□□□□□□□□□□□
- Least Privilege: □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□ just-in-time
- Continuous Monitoring: □□□□□□□□ anomalies □□□□□□□□□□□□□□□□

5.5 Privacy-Preserving AI Techniques

□□□□□□□	□□□□□□□□□□□	□□□□□□□□
Federated Learning	□□□ model □□□□□□□□□□ client □□□□□□□□□□ □□□□□□□□□□□	Mobile learning
Homomorphic Encryption	□□□□□□□□□□□□□□□□□□□ □□□□□□□□□	Secure computation
Secure Multi-Party Computation	□□□□□□□□□□□□□□□□□□□□ □□□	Collaborative analysis
Trusted Execution Environment	□□□□□□□□□□□ secure enclave	Hardware-backed security
Differential Privacy	□□□□□□□□□□□□□□□□□□□□□□ □□□□□□□□□□□□□□□□□□□□□□	Statistical analysis

5.6 MLSecOps Pipeline Security

- Data Security: □□□□, validate, □□□□□□ poisoning
- Model Training: Secure training environment, model versioning
- Model Validation: Adversarial testing, explainability checks
- Deployment: Container scanning, model signing, monitoring
- Runtime Protection: Input validation, output filtering, anomaly detection

5.7 LLM OWASP Top 10 2025

- LLM01: Prompt Injection - □□□□□□□□/□□□□□□□□□□□□ prompt
- LLM02: Insecure Output Handling - □□□□□□□□□□□ output □□□□□□□□□□□□□
- LLM03: Training Data Poisoning - □□□□□□□□□□□□□□□□□□□□□□

- LLM04: Model Denial of Service - □□□ resource □□□□□
- LLM05: Supply Chain Vulnerabilities - □□□□□□□□□□ dependencies
- LLM06: Sensitive Information Disclosure - □□□□□□□ PII □□□ training data
- LLM07: Insecure Plugin Design - Plugin □□□□□□□□□□□□□□
- LLM08: Model Theft - □□□□/□□□□□□□□□□□□□
- LLM09: Insufficient Access Control - □□□□□□□□□□□□□□□□□□□□□□□□
- LLM10: Insecure Model Updating - □□□□□□□□□□□□□□□□□□□□□□□□□□□□

□□□□□ 6: □□□□□□□□□□□□□□□□□□□□

```
│  │    (LDAP/Active Directory)          │   │
│  └──────────────────────────────────────┘   │
│           │         │         │            │
│     ┌─────┴─────┬───┴───┬───┴───┬────┐     │
│     │       │       │       │    │     │
│  ┌──┴──┐ ┌──┴──┐ ┌──┴──┐ ┌──┴──┐  │     │
│  │ Min.│ │ Min.│ │ Min.│ │ Min.│  │     │
│  │Agri.│ │Health│ │Interior│ │...│  │     │
│  └─────┘ └─────┘ └─────┘ └─────┘  │     │
│     │       │       │       │       │     │
│     │       │       │       │       │     │
│  ┌──┴───────┴───────┴───────┴──────┐  │     │
│  │ Shared Document Repository      │  │     │
│  │  (Collabora/ONLYOFFICE)         │  │     │
│  └─────────────────────────────────┘  │     │
│                                       │     │
│  ┌─────────────────────────────┐      │     │
│  │   API Gateway               │      │     │
│  │  (OpenStack, Kong, Nginx)   │      │     │
│  └─────────────────────────────┘      │     │
│                                       │     │
└───────────────────────────────────────┘
```

6.4 Government-Grade Security

- Document Sandboxing: □□□□□□□□□□□□□□□□ sandbox □□□□□□□ malware protection
- End-to-End Encryption: □□□□□□ documents □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□
- Digital Signature: □□□□□ document □□□□ certificate □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□
- Access Control: □□□□□□□□□□ permission □□□□□□□□□/□□□□□□□□□
- Audit Trail: □□

Document Encryption Implementation:

```
// □□□□□□□□□: Document-level encryption
public class SecureDocumentManager {

    public void encryptDocument(String docId, String content) {
        // 1. □□□□□ unique key □□□□□□□□□□□□□□□□□
        byte[] docKey = generateRandomKey(32);  // AES-256

        // 2. □□□□□□□□□ content
        byte[] encryptedContent = encrypt(content, docKey, "AES-256-
GCM");

        // 3. Wrap document key □□□□ user public key
        byte[] wrappedKey = rsaEncrypt(docKey, userPublicKey);

        // 4. □□□□
        database.store(new EncryptedDocument(
            docId,
            encryptedContent,
            wrappedKey,
            metadata
```

```
        ));
    }
}
```

6.5 Local AI Integration with Ollama

□□□ Local AI models □□□ cloud-based LLM □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□

```
# □□□□□□□□□: Ollama setup □□□□□□□ Government
# 1. Install Ollama
curl https://ollama.ai/install.sh | sh

# 2. Pull Thai-capable model
ollama pull mistral  # or llama2

# 3. Run locally
ollama serve

# 4. Use in government application
import requests

response = requests.post(
    'http://localhost:11434/api/generate',
    json={
        'model': 'mistral',
        'prompt': '□□□□□□□□□□□□□□□□□□□□□□□□□□□□'
    }
)

# □□□□□:
# - □□□□□□□□□□□□□□□□□□□□
# - □□□□□□□□□□□□ API fees
# - □□□□□□□□□□□□□□□□□□□□□□□□
# - □□□□□□□□□□□□□□□□□□□□□□□□□□□□
```

6.6 Deployment Sizing & Migration Plan

□□□□	Agencies	Servers	Storage	Budget	Timeline
Phase 1 (Pilot)	5-10	20-30 cores	10-50 TB	5-10M	6 months
Phase 2 (Expansion)	20-50	50-100 cores	100-500 TB	20-50M	12 months
Phase 3 (Full Deployment)	100+	200+ cores	1-10 PB	100M+	24 months

Migration Roadmap:

- Month 1-2: Assessment & Planning - □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□ agency
- Month 3-4: Infrastructure Setup - □□□□□□□□ central cloud, identity management
- Month 5-6: Pilot Deployment - □□□□□□□□□□ 5-10 agencies
- Month 7-12: Expansion - □□□□□□□□□□ agencies □□□□□□□□□□
- Month 13-24: Full Deployment - □□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□□ □□□□□□□□
- Ongoing: Maintenance & Improvements - □□□□□□, patch, enhance

□□□□□□

□□□□□□□□□□□□□□□□□□□